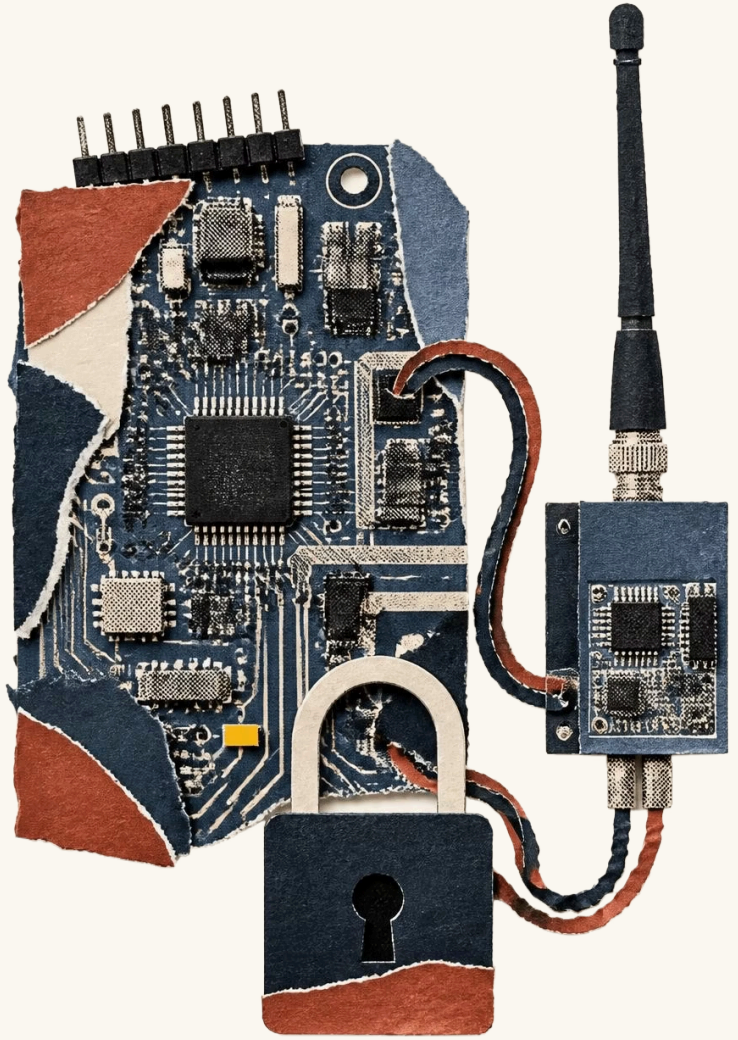
ETHICAL HACKING & DEFENSE · MODULE 08

IoT Hacking: Attacks, Methodology and Defenses

When physical objects join the network, every chip becomes an entry point.

Security Lecture Series · Department of Computer Science & Cybersecurity



Five parts, one path from concepts to countermeasures

1. IoT concepts
2. IoT attacks
3. Hacking methodology
4. Hacking tools
5. Countermeasures

IoT puts the physical world on the network

Sense, send and act: Embedded sensors capture physical telemetry—heat, motion and acoustics; microcontrollers process data; actuators drive physical motion or relay switching.

Where IoT appears: Examples include smart homes and consumer appliances; wearables and telemetry wearables; medical devices, including connected insulin pumps; industrial controllers, including SCADA industrial PLCs; and vehicles, including vehicle ECU telematics units.

Unmanaged and persistent: Billions of autonomous endpoints are often unmanaged: they run unattended for 5 to 15 years in uncontrolled environments, without central administrative oversight or patching.

Physical compromise becomes network compromise.



Every IoT system stacks the same five layers

An attack against any single layer compromises the operational integrity of the entire stack.

LAYER 01

Perception & Edge

Microcontrollers (ARM, ESP32, MIPS), sensors, GPIO, and physical interfaces.

Hardware tampering

LAYER 02

Transport & Gateway

Field gateways, protocol translation hubs, Wi-Fi bridges, and mesh routers.

Traffic interception

LAYER 03

Network & Routing

Edge backhaul, cellular APNs, IPv6 6LoWPAN mesh, and WAN tunnels.

Rogue gateways

LAYER 04

Cloud & Middleware

Data brokers, device shadows, rule engines, analytics, and OTA update servers.

API auth flaws

LAYER 05

Application & UI

Mobile companion apps, web consoles, third-party integrations, and remote telemetry.

Token theft & XSS

Defense in depth is mandatory: hardening the cloud broker does not protect an unauthenticated sensor bus.

Devices talk over many protocols, each with its own weak spots

SHORT RANGE RF

Bluetooth LE · Zigbee · Z-Wave · NFC · RFID

Unauthenticated pairing sequences; default link encryption keys; replay and de-synchronization attacks; radio jamming.

LONG RANGE WIRELESS

LoRaWAN · Cellular (NB-IoT) · Sigfox

Static network join keys (AppKey reuse); cleartext frame counter roll-over; rogue base station and IMSI catching; broadcast spoofing vulnerabilities.

APPLICATION MESSAGING

MQTT · CoAP · HTTP REST

Cleartext broker ports (1883 without TLS); unauthenticated wildcard topic subscriptions; UDP amplification reflection in CoAP; weak API authentication tokens.

How a sensor reaches the cloud: Sensor → Gateway → Cloud

Legacy constraints on bandwidth and power led designers to strip encryption out.

PART 01 · SECURITY OBSTACLES

04

Why IoT is hard to secure

Four structural engineering constraints prevent standard enterprise defenses from working.

You cannot run an EDR agent on an 8-bit microcontroller with 16KB of RAM.

1. Hardware Resource Limits

Low CPU clock rates, tiny SRAM footprints, and battery budgets preclude heavy asymmetric crypto or full TLS stacks.

2. Static Credentials

Factory images ship with hardcoded root passwords, uniform pre-shared keys, and persistent debug credentials across product lines.

3. No Secure OTA Pipeline

Firmware update mechanisms lack cryptographic signing, fail-safe fallback partitions, and authenticated delivery channels.

4. Supply-Chain Fragmentation

White-label OEMs assemble third-party chipsets running abandoned Linux kernels with zero vendor patching accountability.

OWASP IoT vulnerabilities show where devices fail first

VULNERABILITY 01

Weak, Default Passwords

Publicly known credentials (admin/admin, root/12345) baked directly into the bootloader or embedded web UI.

VULNERABILITY 02

Insecure Network Services

Unnecessary listening daemons exposed to the WAN: unauthenticated Telnet, outdated SSH, and open UPnP endpoints.

VULNERABILITY 03

Flawed Cloud & Web Interfaces

Broken object-level authorization (BOLA) in cloud APIs permitting attackers to commandeer arbitrary device accounts.

VULNERABILITY 04

Unencrypted Data Transfer

Lack of TLS in transit exposing credentials, telemetry, and private video feeds to local packet capture.

VULNERABILITY 05

Unverified Update Mechanism

Firmware binaries transmitted over HTTP with no cryptographic signature verification, allowing remote flashing.

VULNERABILITY 06

Insufficient Privacy Protection

Cleartext storage of sensitive PII, biometric tokens, and Wi-Fi WPA keys in unencrypted SPI flash chips.

The OWASP IoT Top 10 remains the benchmark rubric for offensive vulnerability assessment.

The attack surface runs from chip to cloud

Assessors map distinct vector categories spanning the hardware, network, and application planes.

Silicon

Hardware & Storage

UART serial headers, JTAG debug pins, I2C/SPI buses, and flash memory desoldering.

Access: Physical bench

System

Firmware & OS

Hardcoded credentials, outdated BusyBox binaries, kernel memory flaws, and insecure boot sequences.

Access: Direct / Extracted

Signal

Wireless & Radio

RF replay attacks, BLE GATT attribute manipulation, Zigbee network sniffers, and deauth floods.

Access: RF proximity

Service

Cloud & Mobile APIs

Broken object level auth, leaked MQTT broker secrets, insecure direct object references, and CSRF.

Access: Global WAN

If an attacker touches any interface, the perimeter shifts to that layer.

Botnets turn insecure devices into weapons

In 2016, the Mirai botnet scanned the public internet over IPv4 for a trivial hardcoded list of only 62 factory default Telnet credentials.

Over 600,000 IP surveillance cameras and residential DVRs were infected; compromised cameras and routers became the army. DDoS: infected devices flood a target with traffic; Mirai's distributed denial-of-service army was capable of record 1+ Tbps volumetric floods.

One vendor shipping one hardcoded password does not stay isolated: automated worms weaponize the flaw across millions of nodes within hours. Lesson: one weak default scales to millions.

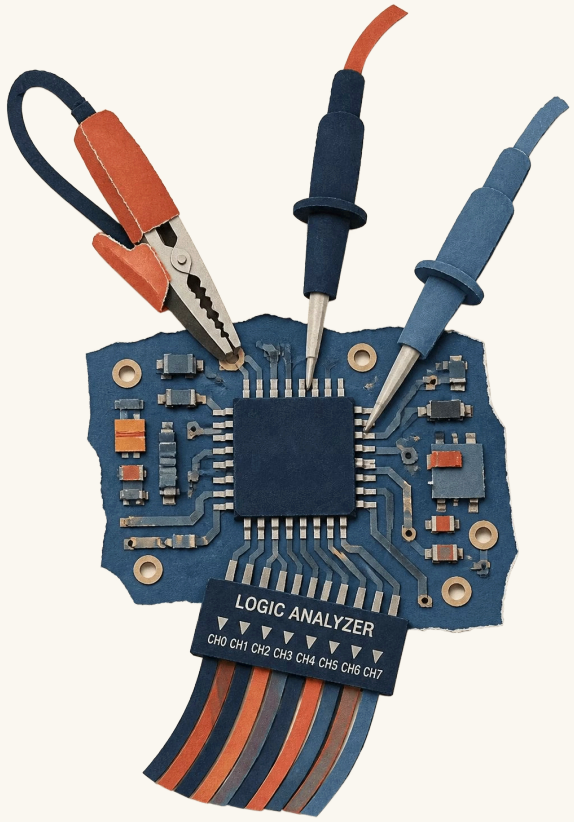
IoT devices make ideal botnet nodes: high uptime, unmonitored bandwidth, and zero host antimalware.



Hardware and firmware attacks start with physical access

- **UART & JTAG debug ports:** Unsoldered PCB pads expose root serial shells, memory access, and CPU register state without authentication.
- **Flash extraction via SPI & I2C:** SOIC-8 test clips dump raw binary from non-volatile flash, even if the processor is locked.
- **Side-channel and fault injection:** Precision voltage drops or clock glitching at boot bypass cryptographic signature checks and disable secure boot protections.
- **Firmware extraction, modification, and backdoors:** Unpack file systems, insert persistent root access daemons, rebuild binaries, and flash the poisoned image back to the PCB.

Given physical custody of a device, total compromise is only a matter of time.



Network and wireless attacks exploit what travels the air

VECTOR 01

RF Sniffing & Replay Attacks

Capture unencrypted sub-GHz transmissions from smart plugs, garage doors, and keyless remotes with a Software Defined Radio; replay them identically. Rolljam defeats rolling codes by jamming the receiver while capturing unspent codes.

VECTOR 02

BLE Interception & GATT Abuse

Bluetooth Low Energy peripherals often use 'Just Works' pairing without MITM defense. Tools can spoof handles and read unencrypted GATT characteristics—a common issue in smart door locks and medical fitness trackers exposing writeable endpoints.

VECTOR 03

Zigbee & 802.15.4 Key Theft

Zigbee networks share a single Link Key during node commissioning. Sniffers near a pairing device can intercept the initial key exchange over the air; default 'ZigBeeAlliance09' master keys allow instant decryption of entire sensor meshes.

VECTOR 04

Rogue Gateways & Spoofing

Higher-priority beacon signals prompt sensors to disassociate from legitimate base stations and register with an attacker-controlled gateway, enabling credential harvesting, telemetry modification, and false command injection.

Airborne signals ignore physical perimeter fences: attackers listen from parking lots and street level.

The IoT hacking methodology follows five phases

A systematic penetration testing workflow comprehensively covers hardware, radio, and cloud planes.

1. Information gathering (Reconnaissance)
Identify FCC IDs, open ports, Shodan exposure, and cloud hosts.

2. Vulnerability scanning (Scanning)
Enumerate listening daemons, default accounts, and known CVEs.

3. Launching attacks (Firmware & Attack)
Extract binaries, reverse-engineer routines, and craft payloads.

4. Gaining remote access (Exploitation)
Execute reverse shells, inject commands, and escalate privilege.

5. Maintaining access (Persistence)
Modify boot scripts, plant backdoors, and log assessment findings.

Discipline separates professional security assessment from unguided tampering.

Phase 1: find the device before you attack it

SPECIALIZED SEARCH ENGINES

Shodan, Censys & Zoomeye

Search exposed IoT banners, SSL certificates, HTTP titles, and locations across global IPv4 and IPv6.

`port:1883 "MQTT"` or `title:"IPCamera"` find unauthenticated endpoints.

REGULATORY OSINT

FCC ID Database

Public filings can include PCB schematics, component photos, RF test frequencies, and block diagrams.

Reveal chip models (e.g., ESP32, RTL8710) and pinouts before buying hardware.

VENDOR DOCUMENTATION

Manuals, Schematics & SDKs

Review developer repositories, GitHub code drops, manufacturer data sheets, and setup guides.

Find factory Wi-Fi SSIDs, setup URLs, and debug pin descriptions.

Pre-engagement reconnaissance provides a blueprint for hardware and software attack vectors.

Phase 2: scan for known and unknown weaknesses

NETWORK SURFACE · PORT & DAEMON FINGERPRINTING

Nmap script/version scans (`-sV -sC`) identify non-standard ports: custom HTTP servers, RTSP video streams (port 554), UPnP (1900), and MQTT (1883/8883), plus outdated BusyBox HTTP daemons and unauthenticated endpoints.

CONFIGURATION AUDIT · AUTOMATED CREDENTIAL TESTING

Test SSH, Telnet, HTTP basic auth, and FTP for factory default credentials with curated wordlists (SecLists, Mirai dictionaries); check first-time setup enforces password changes.

CVE MATCHING · KNOWN VULNERABILITY CORRELATION

Match banners (miniupnpd 1.0, lighttpd 1.4.28) against the National Vulnerability Database for published exploit code, including memory corruption, format strings, and buffer overflows.

ECOSYSTEM BRIDGES · COMPANION APP & API AUDITING

Route companion-app traffic through Burp Suite or OWASP ZAP; bypass certificate pinning with Frida. This exposes IDOR flaws in cloud backends and weak JWT tokens.

IoT scanning audits the ecosystem: device, mobile app, and cloud API combined.

Phase 3: analyze firmware and launch attacks

STEP 01

Extraction

Obtain binaries from vendor update sites, mobile app cache, or SPI flash dumps using flashrom.

STEP 02

Unpacking

Execute Binwalk to carve compressed SquashFS or CramFS file systems from binary blobs.

STEP 03

Secret Hunting

Grep unpacked trees for private RSA keys, hardcoded API tokens, and shadow password hashes.

STEP 04

Emulation & Fuzzing

Spin up QEMU or Firmware Analysis Toolkit to emulate MIPS/ARM binaries and fuzz input handlers.

Launching the attack: Command Injection Case Study

Insecure embedded web interfaces frequently pass user input directly to system command calls without sanitization. An unauthenticated HTTP request containing `admin;telnetd -p 4444 &` spawns an interactive root shell instantly, giving the tester absolute administrative authority over the system.

Firmware analysis strips away security through obscurity by exposing the vendor's source code and secrets.

Phases 4 and 5: gain access and keep it

Access

Reverse shells and backdoors through exposed services

Privilege escalation

Privilege escalation on the embedded OS

Persistence

Persistence through modified firmware or startup scripts

Reporting

Cover tracks, then document findings for the report



Recon and scanning tools map the target

TOOL · CATEGORY	TESTING PHASE	PRIMARY ASSESSMENT PURPOSE
Shodan · Internet Search Engine	Phase 1 · Recon	Locate internet-facing devices, open ports, banners, and default credentials globally.
Censys · Attack Surface Mgmt	Phase 1 · Recon	Map corporate device certificates, host IP footprints, and cloud infrastructure associations.
Nmap · Network Port Scanner	Phase 2 · Scanning	Discover active IP hosts, open TCP/UDP ports, protocol versions; run NSE vulnerability scripts.
Nessus · Vulnerability Scanner	Phase 2 · Scanning	Automated policy compliance auditing, known CVE detection, and default credential audits.
OpenVAS · Open Vulnerability Scanner	Phase 2 · Scanning	Open-source network vulnerability scanning, service misconfiguration detection, and reporting.

Reconnaissance automation quickly reveals whether the target exposes known vulnerable services.

Sniffing, firmware and radio tools go deeper

TOOL	FOCUS
Wireshark	Network traffic
Binwalk and Firmware Analysis Toolkit	Firmware unpacking
Ghidra	Reverse engineering
Ubertooth, HackRF and Bus Pirate	Radio and hardware access

Specialized hardware probes bridge the divide between software logic and physical electrical pins.

Countermeasures start at the device

- Unique credentials per device, no defaults
- Secure boot and signed firmware
- Disable unused ports and debug interfaces
- Encrypt stored data

If the endpoint cannot protect its own boot process, all upstream security fails.



Network and cloud controls limit the blast radius

Network segmentation

Segment IoT devices on their own network.

Traffic encryption

Encrypt traffic with TLS and strong protocol settings.

API security

Secure APIs with authentication and rate limits.

Behavior monitoring

Monitor for unusual device behavior.

Security must cover the whole device lifecycle

Secure design and threat modeling

Regular patching with a trusted update path

Device inventory and monitoring

Secure decommissioning

Key takeaways

IoT expands the attack surface from chip to cloud

Attackers follow a repeatable methodology, so defenders can too

Most breaches trace back to defaults and missing updates

Test only with authorization